

# SOC312 - Unauthorized Template Modification Detected

## SOC Investigation Report

**Analyst:** Ashvin Acharya

**Alert:** SOC312 – Unauthorized Template Modification Detected

**Event ID:** 290

**Classification:** True Positive

---

## 1. Executive Summary

The investigation began with an alert involving the execution of Microsoft Word with the `Normal.dotm` template and a related brute-force attack from the external IP address `181[.]214[.]131.108`.

The investigation established that the attacker first attempted multiple RDP logins and eventually successfully authenticated to the target system using a valid account. After gaining access, the attacker performed several discovery activities to identify the current user, group memberships, privileges, local accounts, and network connections.

Further investigation identified a modification to the Microsoft Word `Normal.dotm` template. The file contained a malicious VBA macro. Analysis of the macro showed that it contacted `hackdev[.]ciaffa[.]net`, retrieved commands from the server, executed them using `cmd /c`, collected the command output, and sent the results back to the same server using an HTTP POST request.

Based on the correlation of authentication logs, endpoint activity, file modification, malicious VBA code, and network activity, the alert was determined to be a **True Positive**.

**Key finding:** The attacker obtained unauthorized access and established malicious functionality through the Microsoft Word `Normal.dotm` template, providing a mechanism for command execution and persistence.

---

## 2. Alert Overview

The alert was triggered by the following process execution:

```
C:\Program Files\Microsoft Office\Office16\WINWORD.EXE
/n /f
C:\Users\LetsDefend\AppData\Roaming\Microsoft\Templates\Normal.dotm
```

The important artifact here is `Normal.dotm`.

`Normal.dotm` is Microsoft Word's default global template. Because Word can load this template when creating or opening documents, modification of the template can be abused to introduce malicious macros.

At this stage, the alert alone did not prove that the template was malicious. Therefore, the next step was to verify the alert through endpoint and log evidence.

EventID :  
Event Time :  
Rule :  
Level :  
Hostname :  
Ip Address :  
Process Name :  
Process Path :  
Parent Process :  
Command Line :  
Trigger Reason :  
Device Action :  
L1 Note :

290  
Aug. 14, 2024, 01:31 PM  
SOC312 - Unauthorized Template Modification Detected  
Incident Responder  
Jonah  
172.16.17.110  
WINWORD.EXE  
C:\Program Files\Microsoft Office\Office16\  
explorer.exe  
"C:\Program Files\Microsoft Office\Office16\WINWORD.EXE" /n /f  
"C:\Users\LetsDefend\AppData\Roaming\Microsoft\Templates\Normal.dotm"  
The default generic template for Microsoft Word, Normal.dotm, has been modified.  
Allowed  
I could not determine whether the command that caused the alert belonged to the attacker. However, I saw a brute force attempt from the IP "181.214.131.108" minutes before the alert occurred.

### 3. Alert Verification

The target system was investigated through Log Management and Endpoint Security.

The relevant command was identified in the endpoint/log data, confirming that the activity which generated the alert actually occurred.

This was important because the initial alert could have represented either legitimate template activity or malicious modification.

The presence of the suspicious `Normal.dotm` execution together with the surrounding attacker activity provided sufficient evidence to continue the investigation.

**Initial assessment: True Positive.**

| Show Filter             |          |               |          |                 |            |     |
|-------------------------|----------|---------------|----------|-----------------|------------|-----|
| Basic Pro               |          |               |          |                 |            |     |
| 172.16.17.110           |          |               |          |                 |            |     |
| DATE                    | TYPE     | SRC ADDRESS   | SRC PORT | DEST. ADDRESS   | DEST. PORT | RAW |
| Aug. 14, 2024, 01:31 PM | OS       | 172.16.17.110 | 0        | 172.16.17.110   | 0          | 🔍   |
| Aug. 14, 2024, 01:32 PM | DNS      | 172.16.17.110 | 0        | 172.16.17.110   | 0          | 🔍   |
| Aug. 15, 2024, 07:59 AM | Firewall | 172.16.17.110 | 27220    | 3.211.157.115   | 443        | 🔍   |
| Aug. 13, 2024, 04:57 PM | Firewall | 172.16.17.110 | 15488    | 13.36.218.177   | 443        | 🔍   |
| Aug. 14, 2024, 04:03 AM | Firewall | 172.16.17.110 | 53523    | 18.66.112.28    | 443        | 🔍   |
| Aug. 14, 2024, 12:39 PM | Firewall | 172.16.17.110 | 15085    | 84.53.185.200   | 443        | 🔍   |
| Aug. 15, 2024, 02:40 AM | Firewall | 172.16.17.110 | 11358    | 104.244.42.65   | 443        | 🔍   |
| Aug. 13, 2024, 11:06 PM | Firewall | 172.16.17.110 | 40323    | 173.194.193.139 | 443        | 🔍   |
| Aug. 14, 2024, 03:15 PM | Firewall | 172.16.17.110 | 42697    | 35.186.241.51   | 443        | 🔍   |
| Aug. 14, 2024, 08:08 PM | Firewall | 172.16.17.110 | 61756    | 31.13.88.174    | 443        | 🔍   |

## 4. Understanding the WINWORD.EXE Command

The command was:

```
WINWORD.EXE /n /f Normal.dotm
```

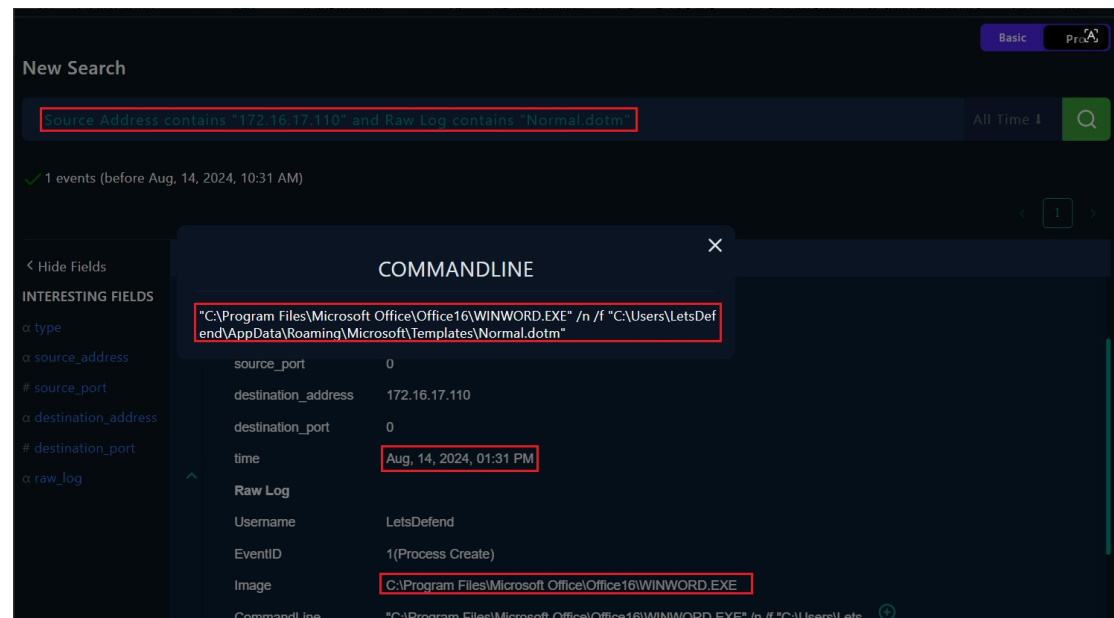
The important part is that Word was instructed to open the `Normal.dotm` template directly.

The investigation considered why an attacker would target this file.

If an attacker modifies `Normal.dotm` and adds malicious VBA code, Word can execute the macro when the template is loaded. This provides an opportunity for an attacker to maintain execution when Word is opened.

The `/n` parameter starts Word without creating a new blank document, while `/f` opens the specified file/template directly.

Therefore, the command itself was not automatically malicious. Its significance came from the fact that the template had been modified and later proved to contain malicious VBA.



## 5. Initial Access - Brute Force

The L1 analyst note identified brute-force activity originating from:

```
181[.]214[.]131[.]108
```

The investigation found numerous requests targeting **port 3389**, indicating RDP activity.

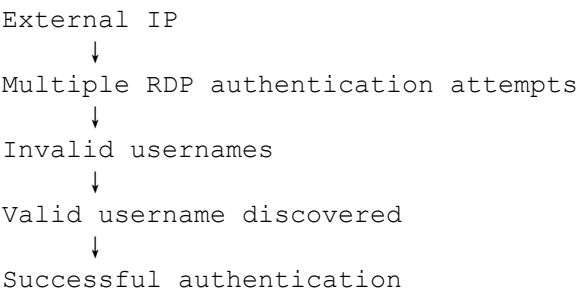
The first authentication attempts failed with:

0xC0000064

This error indicates that the supplied username did not exist.

This pattern was significant because it showed the attacker attempting different usernames before eventually finding a valid account.

The investigation therefore reconstructed the initial access as:



| DATE                    | TYPE | SRC ADDRESS     | SRC PORT | DEST. ADDRESS | DEST. PORT | RAW |
|-------------------------|------|-----------------|----------|---------------|------------|-----|
| Aug, 14, 2024, 01:19 PM | OS   | 181.214.131.108 | 21563    | 172.16.17.110 | 3389       | 🔍   |
| Aug, 14, 2024, 01:19 PM | OS   | 181.214.131.108 | 27453    | 172.16.17.110 | 3389       | 🔍   |
| Aug, 14, 2024, 01:19 PM | OS   | 181.214.131.108 | 24563    | 172.16.17.110 | 3389       | 🔍   |
| Aug, 14, 2024, 01:19 PM | OS   | 181.214.131.108 | 24513    | 172.16.17.110 | 3389       | 🔍   |
| Aug, 14, 2024, 01:19 PM | OS   | 181.214.131.108 | 24785    | 172.16.17.110 | 3389       | 🔍   |
| Aug, 14, 2024, 01:25 PM | OS   | 181.214.131.108 | 24781    | 172.16.17.110 | 3389       | 🔍   |
| Aug, 14, 2024, 01:25 PM | OS   | 181.214.131.108 | 21452    | 172.16.17.110 | 3389       | 🔍   |
| Aug, 14, 2024, 01:25 PM | OS   | 181.214.131.108 | 22458    | 172.16.17.110 | 3389       | 🔍   |
| Aug, 14, 2024, 01:25 PM | OS   | 181.214.131.108 | 22134    | 172.16.17.110 | 3389       | 🔍   |
| Aug, 14, 2024, 01:27 PM | OS   | 181.214.131.108 | 24213    | 172.16.17.110 | 3389       | 🔍   |

## 6. Successful Account Compromise

The investigation then identified a successful RDP login at approximately **01:27 PM**.

The successful authentication demonstrated that the attacker was not merely scanning or attempting access; the attacker actually obtained access to the system.

Relevant evidence:

Username: LetsDefend  
Event ID: 4624  
Logon Type: 10  
Source IP: 181[.]214[.]131[.]108

This established the transition from attempted access to successful account compromise.

MITRE ATT&CK

Based on the observed behavior:

- T1110 – Brute Force
- T1078 – Valid Accounts
- T1133 – External Remote Services

BasicPro

Show Filter

181.214.131.108

| DATE ↓                  | TYPE     | SRC ADDRESS     | SRC PORT | DEST. ADDRESS | DEST. PORT | RAW |
|-------------------------|----------|-----------------|----------|---------------|------------|-----|
| Aug. 14, 2024, 01:27 PM | Firewall | 181.214.131.108 | 24213    | 172.16.17.110 | 3389       | 🔍   |
| Aug. 14, 2024, 01:27 PM |          |                 |          | 16.17.110     | 3389       | 🔍   |
| Aug. 14, 2024, 01:25 PM |          |                 |          | 16.17.110     | 3389       | 🔍   |
| Aug. 14, 2024, 01:25 PM |          |                 |          | 16.17.110     | 3389       | 🔍   |
| Aug. 14, 2024, 01:25 PM |          |                 |          | 16.17.110     | 3389       | 🔍   |
| Aug. 14, 2024, 01:25 PM |          |                 |          | 16.17.110     | 3389       | 🔍   |
| Aug. 14, 2024, 01:25 PM | OS       | 181.214.131.108 | 22458    | 172.16.17.110 | 3389       | 🔍   |
| Aug. 14, 2024, 01:25 PM | OS       | 181.214.131.108 | 21452    | 172.16.17.110 | 3389       | 🔍   |
| Aug. 14, 2024, 01:25 PM | OS       | 181.214.131.108 | 24781    | 172.16.17.110 | 3389       | 🔍   |
| Aug. 14, 2024, 01:25 PM | Firewall | 181.214.131.108 | 24781    | 172.16.17.110 | 3389       | 🔍   |

×

RAW LOG

Username: letsdefend

EventID: 4624(An account was successfully logged on.)

Logon Type: 10(RemoteInteractive)

Source IP: 181.214.131.108

7. Reputation Check

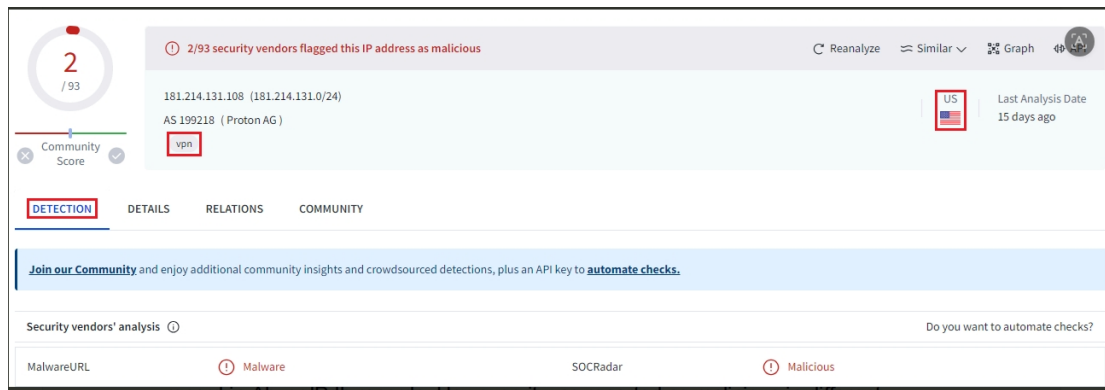
The source IP 181[.]214[.]131[.]108 was investigated using reputation sources.

The results were mixed. AbuseIPDB did not show a risk record, while VirusTotal contained malicious reports from different sources.

This demonstrates an important SOC principle:

A clean reputation result does not prove that an IP is benign.

The behavior observed from the IP was more important than reputation alone because the IP had performed brute-force activity and subsequently achieved successful authentication.



## 8. Post-Compromise Discovery

After obtaining access, the attacker executed several commands:

```
whoami
whoami /groups
whoami /priv
netstat -an
net user
ping hackdev.ciaffa.net
```

These commands indicate that the attacker was trying to understand the compromised environment.

### Command analysis

| Command                    | Purpose                                                             |
|----------------------------|---------------------------------------------------------------------|
| whoami                     | Identifies the current user                                         |
| whoami /groups             | Identifies group memberships                                        |
| whoami /priv               | Displays available privileges                                       |
| netstat -an                | Displays network connections and listening ports                    |
| net user                   | Enumerates local user accounts                                      |
| ping<br>hackdev.ciaffa.net | Tests connectivity to the external domain and causes DNS resolution |

### MITRE ATT&CK mapping

The strongest mappings supported by the observed commands are:

- **T1033 – System Owner/User Discovery** → `whoami`
- **T1069 – Permission Groups Discovery** → `whoami /groups`
- **T1087.001 – Account Discovery: Local Account** → `net user`
- **T1049 – System Network Connections Discovery** → `netstat -an`

I would **not** claim keylogging from this command sequence. There is no evidence here of a keylogger.

---

## 9. Investigating Normal.dotm

The next step was to determine whether `Normal.dotm` had actually been modified.

The file was located at:

```
C:\Users\LetsDefend\AppData\Roaming\Microsoft\Templates\Normal.dotm
```

The file showed:

```
LastWriteTime: 8/14/2024 1:32:02 PM  
Size: 24002 bytes
```

The timestamp was highly relevant because it occurred during the same period as the compromise.

However, the timestamp alone was not treated as proof of malicious activity.

The file needed to be inspected.

---

## 10. Malicious VBA Macro Discovery

Inspection of the `Normal.dotm` VBA project revealed code under:

```
Normal  
└── Microsoft Word Objects  
    └── ThisDocument
```

The macro contained:

```
Const callbackUrl = "http://hackdev.ciaffa.net"
```

and created:

```
WScript.Shell
```

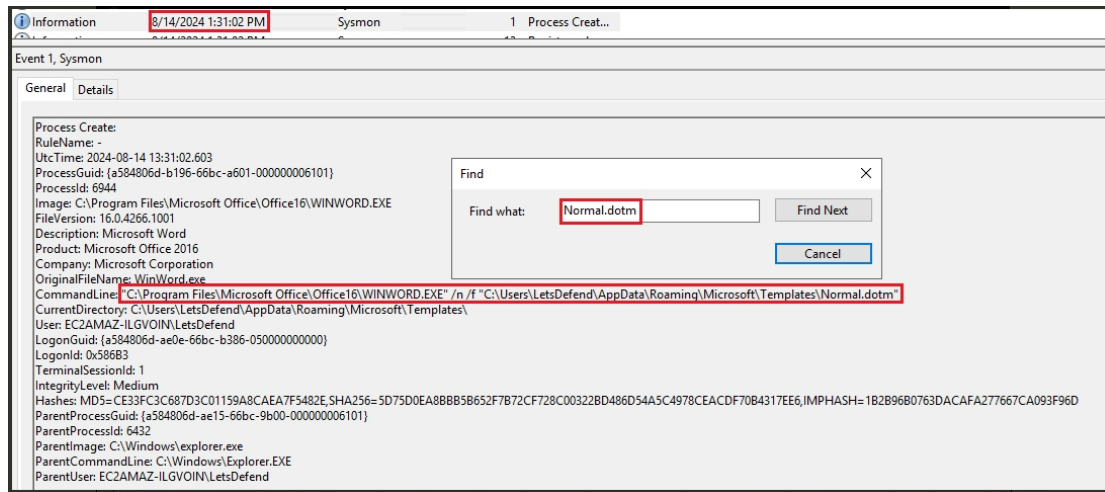
It also created an HTTP object using:

```
MSXML2.ServerXMLHTTP
```

This changed the investigation significantly.

The file was no longer simply a modified Word template.

It contained code capable of communicating with an external server and executing commands.



## 11. Macro Behavior Analysis

The macro follows a command-and-control loop.

### Step 1 - Contact C2

The macro sends an HTTP GET request to:

`http://hackdev.ciaffa.net`

### Step 2 - Receive a command

The server response is treated as a command.

### Step 3 - Execute the command

The macro constructs:

```
cmd /c <received command>
```

and executes it through `WScript.Shell`.

### Step 4 - Collect output

The output of the command is read from:

`StdOut`

## Step 5 - Send output back

The result is sent to the same C2 server using an HTTP POST request.

## Step 6 - Continue

The process continues until the server sends:

EXIT

Conceptually:

Word opens



VBA macro executes



HTTP GET



C2 sends command



cmd /c executes command



Command output collected



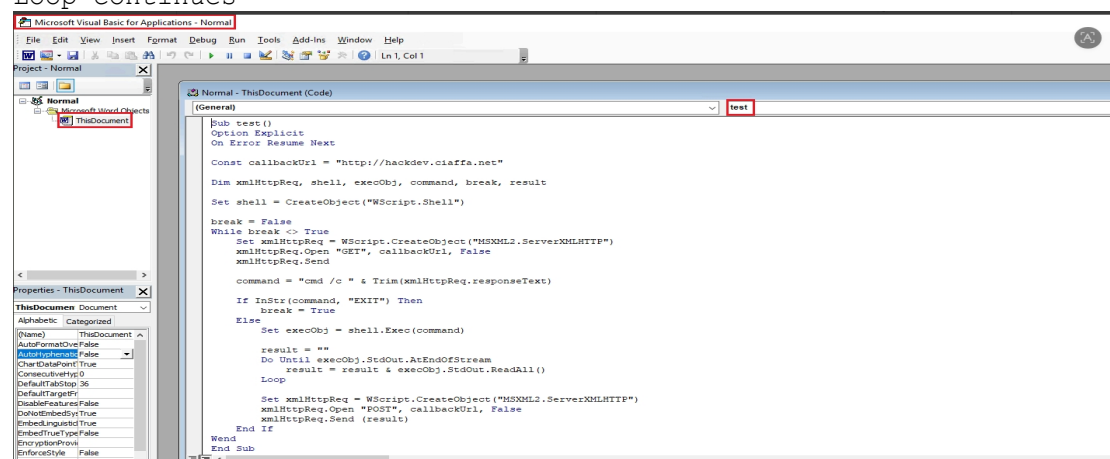
HTTP POST



Output returned to attacker



Loop continues



## 12. DNS and Network Correlation

The domain:

hackdev.ciaffa.net

was also observed in endpoint activity.

The DNS query resolved to:

18.199.84.226

The important correlation was:

```
Macro
↓
hackdev.ciaffa.net
↓
DNS resolution
↓
18.199.84.226
```

This provided network evidence supporting the malicious functionality discovered inside the template.

---

## 13. MITRE ATT&CK Mapping

Based on the evidence reviewed during the investigation:

| Tactic         | Technique                                                      | Evidence                             |
|----------------|----------------------------------------------------------------|--------------------------------------|
| Initial Access | T1110 - Brute Force                                            | Multiple RDP authentication attempts |
| Initial Access | T1078 - Valid Accounts                                         | Successful login using LetsDefend    |
| Initial Access | T1133 - External Remote Services                               | RDP-based remote access              |
| Discovery      | T1033 - System Owner/User Discovery                            | whoami                               |
| Discovery      | T1069 - Permission Groups Discovery                            | whoami /groups                       |
| Discovery      | T1087.001 - Account Discovery: Local Account                   | net user                             |
| Discovery      | T1049 - System Network Connections Discovery                   | netstat -an                          |
| Persistence    | T1137.001 - Office Application Startup: Office Template Macros | Malicious VBA stored in Normal.dotm  |
| Execution      | T1059.005 - Command and Scripting Interpreter: Visual Basic    | Malicious VBA                        |
| Command and    | T1071.001 - Web Protocols                                      | HTTP GET/POST                        |

| Tactic  | Technique | Evidence      |
|---------|-----------|---------------|
| Control |           | communication |

---

## 14. Defense Evasion Question

The lab presented **Template Injection** as one of the possible Defense Evasion answers.

From an analyst-learning perspective, however, the important distinction is:

The observed modification of Normal.dotm clearly establishes **Office Template Macro persistence**. The evidence supplied does not independently demonstrate that the modification was performed specifically to evade security controls.

Defense Evasion: Template Injection

For your **MITRE learning section**, retain:

T1137.001 - Office Application Startup: Office Template  
Macros

---

## 15. IOC / Artifacts

The investigation identified the following indicators:

| Type          | Indicator                                                           |
|---------------|---------------------------------------------------------------------|
| Attacker IP   | 181[.]214[.]131[.]108                                               |
| Host          | Jonah / 172[.]16[.]17[.]110                                         |
| C2 URL        | hxxp://hackdev.ciaffa[.]net                                         |
| File          | Normal.dotm                                                         |
| Template path | C:\Users\LetsDefend\AppData\Roaming\Microsoft\Templates\Normal.dotm |
| C2 resolve    | 18[.]199[.]84[.]226                                                 |
| d IP          |                                                                     |

## 16. Containment

Because the attacker successfully obtained unauthorized access, the affected system should be isolated from the network to prevent additional attacker activity or lateral movement.

Recommended actions include:

1. Isolate the affected endpoint.
  2. Reset or disable the compromised account.
  3. Remove the malicious `Normal.dotm`.
  4. Replace the template with a known-good copy.
  5. Hunt for the C2 domain and attacker IP across other systems.
  6. Review additional commands executed after compromise.
  7. Investigate whether additional persistence mechanisms were created.
- 

## 17. Detection Improvement

A useful detection opportunity is monitoring modifications to:

`\AppData\Roaming\Microsoft\Templates\Normal.dotm`

This can be strengthened by correlating the file modification with:

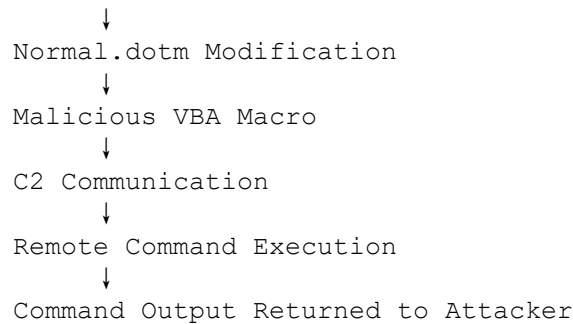
- Microsoft Word process creation
  - VBA/macro execution
  - suspicious child processes
  - network connections
  - external domains
  - unusual user activity
- 

## 18. Final Conclusion

The SOC312 alert was determined to be a **True Positive**.

The investigation established the following attack chain:

```
Brute Force
  ↓
Successful RDP Authentication
  ↓
Valid Account Compromise
  ↓
Discovery Activity
```



The strongest evidence was the correlation between the compromised account, the modification of `Normal.dotm`, the malicious VBA code, and the C2 infrastructure.

The malicious macro effectively transformed the Word template into a mechanism for receiving and executing attacker-controlled commands.

Therefore, the incident should be treated as a **confirmed compromise**, rather than an isolated suspicious template modification.

---

## 19. Analyst Learning / Takeaways

This investigation reinforced several important SOC investigation principles:

### 1. Do not rely only on IOC reputation

An IP can have a clean reputation record and still be malicious in a specific incident.

### 2. Correlate events

A single event may be ambiguous. Multiple related events can establish an attack chain.

### 3. Investigate the artifact itself

The `Normal.dotm` timestamp was suspicious, but inspecting the VBA code provided the actual proof of malicious functionality.

### 4. Understand attacker intent

The attacker did not modify the template randomly. The modification provided a way to execute malicious code through Microsoft Word.

### 5. MITRE ATT&CK should be evidence-driven

Instead of asking:

"Which MITRE technique can I attach to this?"

ask:

"What did the attacker actually do, and which technique describes that behavior?"

## 6. Don't overclaim

For example, the commands showed discovery activity, but they did **not** provide evidence of keylogging.